Cyber Risk Assessment

Quick briefing

Assess defensive cyber risks by linking a valued asset, a credible threat and a weakness to likelihood and mission impact.

Know the facts

CIA triad · Confidentiality limits disclosure to authorized parties, integrity protects accuracy and authenticity, and availability keeps information and systems usable when needed.

Asset, threat and vulnerability · An asset has value, a threat can cause harm, and a vulnerability is a weakness that a threat could exploit.

Risk · Risk combines the likelihood that a threat exploits a vulnerability with the resulting impact on the mission.

People, Process and Technology · The lesson groups assessment evidence under people's practices and readiness, processes for governing and maintaining ICT, and hardware and software safeguards.

Six incident-response phases · Preparation, identification, containment, eradication, recovery, and assessment and review.

Recovery evidence · A restore test verifies that backup data can be recovered. Recovery from an incident also includes monitoring restored services.

Understand the reasoning

A weakness becomes more urgent when a credible threat can exploit it during a mission-critical period. The same weakness may have a lower impact in a disposable training system.

Containment limits the spread or impact of an incident. Eradication removes the cause or malicious components before returning to normal service.

Philippine Army classroom exercise

A fictional Philippine Army training center depends on an online course roster during graduation week. The only backup is kept on the same system, and a low-use practice kiosk is overdue for maintenance.

Decision · What should the team verify first before allocating its one available maintenance period?

Worked analysis · Verify whether the roster has an independent, recoverable copy and test restoration in the approved training environment. Loss of the live system could otherwise remove both the roster and its backup at a critical time. Record the kiosk risk and reconsider the order if its use or exposure changes.

How to practice

1 · List the assets that support the classroom mission and identify what each needs for confidentiality, integrity and availability.

2 · For each asset, state a plausible threat, the weakness it could exploit and the consequence for the mission.

3 · Use the exercise’s supplied scoring rules or documented criteria to rate likelihood and impact.

4 · Prioritize controls, identify who owns each change, and collect evidence that the controls work.

5 · Update the assessment when exposure, controls or mission needs change.

Check yourself

Is a missing access restriction a threat or a vulnerability? · A vulnerability. It is a weakness that a threat could exploit.

Which incident phase limits spread before the cause is removed? · Containment.

Course source

Cyber Risk Assessment